

ISO/IEC 27001 — Sistemas de Gestión de Seguridad de la Información

1. Introducción y contexto

ISO/IEC 27001 es la norma internacional de referencia para establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de Seguridad de la Información (SGSI), conocido en inglés como ISMS (Information Security Management System). Pertenece a la familia de normas ISO/IEC 27000, dedicada íntegramente a la seguridad de la información. A diferencia de un enfoque puramente técnico de la ciberseguridad (firewalls, antivirus, cifrado), ISO/IEC 27001 propone un enfoque de gestión: la seguridad de la información se trata como un proceso organizacional continuo, con responsables, objetivos medibles, y mejora constante, en lugar de un conjunto fijo de controles técnicos. Para un estudiante de Informática, comprender esta norma es clave porque conecta el conocimiento técnico (redes, sistemas, desarrollo seguro) con la gestión de riesgos y el cumplimiento normativo que exigen las organizaciones modernas.

2. Historia y evolución

- El origen de ISO/IEC 27001 se remonta al estándar británico BS 7799, publicado por la British Standards Institution (BSI) en 1995, que definía buenas prácticas de seguridad de la información.
- En 2000, la parte 1 de BS 7799 fue adoptada como ISO/IEC 17799, un código de buenas prácticas.
- En 2005 se publicó formalmente ISO/IEC 27001:2005, basada en la parte 2 de BS 7799, introduciendo el modelo de sistema de gestión certificable.
- En 2013 se publicó una revisión importante, ISO/IEC 27001:2013, que alineó su estructura con el llamado "Anexo SL" o Estructura de Alto Nivel (HLS), común a todas las normas modernas de sistemas de gestión ISO (igual que ISO 9001 o ISO 14001), facilitando la integración entre sistemas.
- La versión vigente más reciente es ISO/IEC 27001:2022, que actualizó y reorganizó los controles de seguridad del Anexo A, reduciéndolos de 114 a 93, agrupados en cuatro grandes categorías en lugar de catorce dominios.

3. Objetivo y alcance

El objetivo central de la norma es ayudar a las organizaciones a proteger tres propiedades fundamentales de la información, conocidas como la tríada CIA:

- **Confidencialidad:** que la información solo sea accesible para quienes están autorizados.
- **Integridad:** que la información sea exacta y completa, y no se altere de forma no autorizada.
- **Disponibilidad:** que la información esté accesible cuando se necesite.

La norma es aplicable a organizaciones de cualquier tamaño y sector: empresas de software, bancos, hospitales, universidades, gobiernos, startups, etc. No prescribe tecnologías específicas, sino un marco de gestión adaptable al contexto de cada organización.

4. Organismo emisor y proceso de normalización

ISO/IEC 27001 es desarrollada conjuntamente por la Organización Internacional de Normalización (ISO) y la Comisión Electrotécnica Internacional (IEC), a través del comité técnico conjunto ISO/IEC JTC 1, subcomité SC 27 (Seguridad de la información, ciberseguridad y protección de la privacidad). Las normas se desarrollan mediante consenso entre expertos de comités nacionales de normalización de distintos países, con revisiones periódicas (normalmente cada 5 años).

5. Estructura general de la norma

La norma ISO/IEC 27001:2022 sigue la Estructura de Alto Nivel común a las normas de sistemas de gestión, compuesta por diez cláusulas principales:

1. Objeto y campo de aplicación
2. Referencias normativas
3. Términos y definiciones
4. Contexto de la organización
5. Liderazgo
6. Planificación
7. Soporte
8. Operación
9. Evaluación del desempeño
10. Mejora

A esto se añade el Anexo A, un listado de referencia de controles de seguridad organizados en cuatro categorías: organizacionales, de personas, físicos y tecnológicos.

6. Conceptos y terminología clave

- SGSI (Sistema de Gestión de Seguridad de la Información): conjunto de políticas, procedimientos, procesos y recursos orientados a gestionar la seguridad de la información de forma sistemática.
- Activo de información: cualquier elemento que tenga valor para la organización (datos, sistemas, personas, infraestructura, reputación).
- Riesgo de seguridad de la información: efecto de la incertidumbre sobre los objetivos de seguridad, generalmente expresado como combinación de probabilidad e impacto de una amenaza que explota una vulnerabilidad.
- Declaración de aplicabilidad (SoA – Statement of Applicability): documento que especifica qué controles del Anexo A se aplican, cuáles no, y por qué.
- Tratamiento del riesgo: proceso de seleccionar e implementar medidas para modificar el riesgo (mitigar, transferir, evitar o aceptar).
- Mejora continua: principio según el cual el SGSI debe revisarse y perfeccionarse de forma periódica, típicamente mediante el ciclo PDCA (Plan-Do-Check-Act).

7. Principios fundamentales

- Enfoque basado en riesgos: las decisiones de seguridad se justifican mediante evaluaciones de riesgo, no por intuición.
- Liderazgo y compromiso de la alta dirección: la seguridad no es solo un tema técnico, requiere respaldo directivo y asignación de recursos.
- Enfoque de proceso y mejora continua (PDCA): planificar, implementar, verificar y actuar de forma cíclica.
- Documentación controlada: políticas, procedimientos y registros deben mantenerse, revisarse y actualizarse de forma trazable.
- Enfoque en resultados medibles: se establecen objetivos de seguridad con indicadores verificables.

8. Cláusulas principales explicadas (resumen conceptual)

4. Contexto de la organización

Exige identificar factores internos y externos relevantes, así como las partes interesadas (clientes, reguladores, empleados) y sus expectativas en materia de seguridad, definiendo también el alcance del SGSI.

5. Liderazgo

Establece que la alta dirección debe demostrar compromiso, definir una política de seguridad de la información, y asignar roles y responsabilidades claras.

6. Planificación

Introduce la obligación de identificar riesgos y oportunidades, realizar una evaluación de riesgos formal, definir un plan de tratamiento de riesgos y objetivos de seguridad medibles.

7. Soporte

Cubre los recursos necesarios (personal, infraestructura), competencia y formación del personal, concienciación, comunicación interna/externa, y control de la información documentada.

8. Operación

Requiere planificar y controlar los procesos operativos necesarios para cumplir los requisitos de seguridad, incluyendo la ejecución de la evaluación y el tratamiento de riesgos.

9. Evaluación del desempeño

Incluye monitoreo, medición, análisis, auditorías internas y revisión por la dirección del SGSI.

10. Mejora

Exige gestionar no conformidades, acciones correctivas y promover la mejora continua del sistema. Anexo A — Categorías de controles (versión 2022) • Controles organizacionales (37 controles): políticas, roles, gestión de activos, control de acceso, relaciones con proveedores, gestión de incidentes, continuidad de negocio, cumplimiento legal. • Controles de personas (8 controles): selección de personal, términos de empleo, concienciación y formación, procesos disciplinarios. • Controles físicos (14 controles): seguridad de instalaciones, equipos, eliminación segura de medios, cableado. • Controles tecnológicos (34 controles): control de acceso a sistemas, criptografía, seguridad de redes, desarrollo seguro, gestión de vulnerabilidades técnicas, backups.

9. Proceso de implementación (ciclo PDCA aplicado al SGSI)

11. Plan (Planificar): definir alcance, política de seguridad, metodología de evaluación de riesgos,

identificar activos, amenazas y vulnerabilidades, y elaborar el plan de tratamiento de riesgos.

12. Do (Hacer): implementar los controles seleccionados, capacitar al personal, y ejecutar los procesos

definidos.

13. Check (Verificar): realizar auditorías internas, monitorear indicadores de seguridad y revisar el

desempeño del sistema.

14. Act (Actuar): corregir no conformidades, actualizar riesgos y controles, y mejorar el sistema de

forma continua. La certificación bajo ISO/IEC 27001 es otorgada por organismos de certificación acreditados, tras una auditoría externa en dos etapas (revisión documental y auditoría de implementación), con auditorías de seguimiento anuales.

10. Relación con otras normas

- ISO/IEC 27002: código de buenas prácticas que detalla cómo implementar cada control del Anexo A. Se usa como complemento directo de ISO/IEC 27001.
- ISO/IEC 27005: guía específica para la gestión de riesgos de seguridad de la información.
- ISO/IEC 27017 / 27018: controles adicionales para seguridad y privacidad en la nube.
- ISO 22301: gestión de continuidad de negocio, relacionada con la disponibilidad de la información.
- ISO 9001: comparte la Estructura de Alto Nivel, lo que facilita sistemas de gestión integrados (calidad + seguridad).

11. Aplicación práctica en informática y desarrollo de software

- Definición de políticas de control de acceso en sistemas y bases de datos.
- Gestión segura del ciclo de vida del desarrollo de software (SDLC seguro).
- Clasificación de la información y cifrado de datos sensibles en tránsito y en reposo.
- Gestión de incidentes de seguridad (detección, respuesta, lecciones aprendidas).
- Auditoría de accesos y registros (logs) en sistemas críticos.
- Evaluación de riesgos en proyectos de migración a la nube o adopción de nuevas tecnologías.

12. Caso de aplicación ilustrativo

Una empresa de desarrollo de software que maneja datos de clientes decide implementar un SGSI. Primero identifica sus activos críticos (código fuente, bases de datos de clientes, credenciales de acceso a servidores). Luego evalúa riesgos como accesos no autorizados o fugas de código fuente, y selecciona controles del Anexo A como autenticación multifactor, cifrado de bases de datos y acuerdos de confidencialidad con proveedores. Finalmente, mide la eficacia de estos controles mediante auditorías internas periódicas y ajusta el sistema según los resultados obtenidos.

13. Preguntas de repaso

- ¿Qué diferencia existe entre un enfoque técnico de la ciberseguridad y el enfoque de gestión propuesto por ISO/IEC 27001?
- ¿Qué representa la tríada CIA y por qué es central en la norma?
- ¿Cuál es la función de la Declaración de Aplicabilidad (SoA)?
- ¿Cómo se relaciona el ciclo PDCA con las cláusulas 4 a 10 de la norma?
- ¿Qué diferencia hay entre ISO/IEC 27001 e ISO/IEC 27002?
- Menciona dos controles tecnológicos del Anexo A y explica su propósito.

14. Glosario breve

- Amenaza: causa potencial de un incidente no deseado.
- Vulnerabilidad: debilidad que puede ser explotada por una amenaza.
- Incidente de seguridad: evento que compromete la confidencialidad, integridad o disponibilidad de la información.
- No conformidad: incumplimiento de un requisito del sistema de gestión.
- Auditoría interna: evaluación sistemática realizada por la propia organización para verificar el cumplimiento del SGSI.

15. Para profundizar

Este documento es un material de apoyo educativo. Para el estudio formal y la certificación profesional, se recomienda consultar el texto oficial de ISO/IEC 27001:2022 a través de los canales autorizados de ISO (iso.org) o de los organismos nacionales de normalización, así como cursos oficiales de implementadores y auditores líderes.